

Audience Ministérielle — Pitch et Questions Anticipées

Plateforme Nationale de Pilotage Industriel (PNPI) Préparation audience Ministre de l'Industrie Semaine du 5–10 mai 2026

1. PITCH D'OUVERTURE — 90 SECONDES

À dire à voix haute, apprendre par cœur. Ton respectueux, phrases courtes.

Monsieur le Ministre, je suis venu vous présenter la **Plateforme Nationale de Pilotage Industriel**, qu'on appelle la PNPI. Elle est **déjà construite, entièrement fonctionnelle, et prête à servir l'État dès aujourd'hui**.

Ce n'est pas une promesse — vous pouvez la voir, la tester, parcourir son code. C'est un outil web et mobile qui digitalise en totalité le workflow des Agrément Techniques Industriels : de la soumission par l'opérateur, à l'instruction par vos agents, à la décision ministérielle, jusqu'à la vérification publique par code QR.

Pourquoi vous la présente-t-on ? Parce que le Gabon mérite une plateforme de gouvernance industrielle souveraine, conçue ici, pilotée ici, dont les données restent ici. **Je vous offre l'usage à perpétuité**. Votre État en sera le propriétaire du droit d'usage, exclusif sur le territoire gabonais.

En retour, je vous demande une convention de maintenance annuelle pour que la plateforme reste vivante, sécurisée, et qu'elle évolue selon vos besoins.

Mais il y a un troisième enjeu : **je garde la propriété intellectuelle**. Non pas pour vous l'échapper, mais pour la porter dans la CEMAC — Cameroun, Congo, Tchad, Centrafrique, Guinée Équatoriale. Le Gabon devient ainsi la vitrine de ce que peut produire la jeunesse tech gabonaise. C'est un soft-power qui vous coûte zéro franc supplémentaire.

Voilà le partage que je propose : un outil souverain pour l'État, une viabilité pour moi, et une ambassade numérique pour le Gabon. Êtes-vous d'accord pour que je vous la montre en détail ?

2. SCRIPT DE DÉMONSTRATION — 10 MINUTES CHRONO

Plan minute par minute. Écran + paroles. Transition annoncée d'avance.

0:00–1:00 — LANDING, IDENTITÉ VISUELLE, CONNEXION ADMIN

À l'écran : - Ouvrir <https://pnpi.gov.ga> (ou instance de démo) - Afficher la landing page : bandeau République Gabonaise (vert/jaune/bleu), logo PNPI - Parcourir la page : section "À propos", section "Vérifier un certificat" (public) - Connexion : écran de login avec logo

À dire : « Voici la PNPI telle que vos citoyens la verront. L'identité visuelle est celle du Gabon — les couleurs que vous voyez, c'est votre drapeau. Chaque écran, chaque formulaire, porte la marque de l'État gabonais.

Maintenant je me connecte en tant qu'administrateur du système. »

Cliquer sur login, entrer les credentials admin.

Transition : « Vous me voyez côté Cabinet maintenant. Mais la PNPI, c'est surtout une plateforme pour **six profils d'utilisateurs**. Je vais vous les montrer un par un, en commençant par celui qui arrive en premier : l'opérateur industriel. »

1:00–2:30 — OPÉRATEUR INDUSTRIEL : DÉPÔT D'ATI

À l'écran : - Basculer sur un compte opérateur (ou switch de rôle si possible) - Naviguer vers « Mes ATI » / « Soumettre une ATI » - Afficher le formulaire avec modèles pré-remplis par secteur (exemple : agroalimentaire, bois, mines) - Montrer les champs : raison sociale, NIF, secteur, localisation GPS, capacité de production - Cliquer sur « Ajouter pièces justificatives » - Montrer le gestionnaire de fichiers : upload d'un certificat ISO, du plan d'usine, du CV du gérant (exemple : fichiers tests) - Validation du formulaire, soumission - Écran de confirmation : numéro d'ATI généré, date de réception, statut = « En instruction »

À dire : « Voici comment fonctionne le guichet opérateur. Un industriel du secteur agroalimentaire arrive. Il n'a pas besoin de bureau à Libreville, pas besoin de papier. Il se connecte 24 heures sur 24, 7 jours sur 7.

Vous voyez le formulaire — il est pré-configuré avec les documents attendus pour son secteur. Les opérateurs me disent que ça leur épargne les allers-retours : ils savent exactement ce qu'on attend.

Une fois soumis, le système génère un numéro. Instantanément, l'ATI entre dans le workflow d'instruction. Et l'opérateur reçoit un QR code — il peut le partager, le mettre sur sa carte de visite. Ses clients et partenaires peuvent vérifier en direct que son agrément est valide. »

Transition : « Maintenant l'ATI est soumise. Elle entre dans le bureau de l'instructeur. C'est là que commence le contrôle de conformité. »

2:30–4:00 — INSTRUCTEUR : INSTRUCTION DU DOSSIER

À l'écran : - Basculer sur un compte instructeur - Naviguer vers le **tableau Kanban** : colonnes « À analyser », « En cours », « Validé », « Besoin d'info » - Afficher l'ATI qu'on vient de soumettre dans « À analyser » - Ouvrir le dossier : résumé opérateur, historique, tous les documents uploadés - Montrer la **checklist de conformité** : 12 items pré-configurés pour le secteur agroalimentaire - « Certificat ISO valide » — avec case à cocher - « Plan d'usine au 1/100e » — avec case à cocher - « Capacité = production déclarée » — scoring automatique - « Pas d'antécédent de non-conformité » — requête historique - Montrer le **score de risque** composite : affichage 42/100 (risque modéré, jaune) - Cliquer sur « Recommandation IA » : système propose « Approuver avec conditions » - Ajouter un **commentaire interne** : « À vérifier : la capacité est 25 % plus élevée que déclarée. Demander une clarification. » - Basculer le statut à « Besoin d'info » - Notification auto : l'opérateur reçoit un message - Afficher le **fil d'audit** en bas : « 14:32 — Instructeur créé le dossier », « 14:35 — Demande d'info envoyée »

À dire : « La PNPI automatise la conformité. Un instructeur arrive le matin. Il voit une file de dossiers, classés par priorité. Pas besoin de perdre du temps à imprimer, à annoter, à classer dans des dossiers papier.

Il ouvre, il voit immédiatement ce qui manque. Le système lui suggère un scoring de risque — basé sur six facteurs : capacité de production, historique, localisation géographique, profil du gérant, antécédents, données publiques. L'IA propose même un avis.

Bien sûr, c'est lui qui décide. Ici, par exemple, le risque semble modéré mais il y a une incohérence. Il ajoute un commentaire, et l'opérateur est notifié **en direct**, pas par courrier une semaine plus tard.

Tout est tracé — audit complet. Qui a vu le dossier, quand, qu'est-ce qu'il a noté. C'est transparent, c'est rapide, c'est traçable. »

Transition : « Une fois que l'opérateur a répondu et que tout est conforme, le dossier remonte vers la direction pour signature. »

4:00–5:00 — DIRECTEUR : TABLEAU DE BORD, SIGNATURE

À l'écran : - Basculer sur un compte directeur - Naviguer vers le **Tableau de bord directeur** - Afficher les **KPIs du jour** : - 42 ATI en instruction (en baisse de 8 % vs semaine dernière) - Délai moyen : 28 jours (objectif : 35 jours) ✓ - Taux de conformité : 87 % - 3 appels en attente (urgence signalée) - Montrer le **graphique de tendance** : courbe d'ATI par mois sur 12 mois, avec variation saisonnière - Naviguer vers « Approvals » : afficher une ATI en attente de signature - Ouvrir le certificat proposé, vérifier les détails, cliquer « Signer » - Affichage : signature électronique apposée, date/heure, nom du directeur - Certificat généré en PDF, avec QR code

À dire : « Ici, c'est le point de vue du directeur. Il ne veut pas de détails d'instruction — il veut voir le résumé exécutif. La PNPI lui donne ça sur une seule page : combien d'ATI en transit, quel délai, quel taux de conformité.

Les données sont **en temps réel**. Pas de rapport du vendredi qui arrive lundi matin. C'est maintenant.

Quand un dossier est prêt, il suffit de cliquer pour approuver. Une signature électronique est apposée, le certificat est généré, l'opérateur est notifié. C'est instantané. »

Transition : « Mais le vrai pilotage, c'est le regard ministériel. C'est ce que je vous montre maintenant. »

5:00–6:30 — MINISTRE : VISION GLOBALE, KPIS, BRIEFING AUDIO

À l'écran : - Basculer sur un compte Ministre - Naviguer vers le **Tableau de bord Ministre** - Afficher les **9 KPIs stratégiques** en grands chiffres : - **1 847** ATI actives (cumul depuis lancement) - **42** secteurs couverts - **15 743** emplois industriels déclarés - **Délai moyen** 32 jours (objectif 30j) — jaune - **Conformité** 91 % — vert - **Couverture provinciale** 9/9 provinces — vert - **Investissements** déclarés 847 milliards FCFA - **Empreinte carbone** sectorielle : tendance - **Impact ODD** : 5 objectifs de développement durable contribués - Montrer la **carte du Gabon** avec heat-map par province : provinces avec plus d'ATI = rouge, moins = bleu clair - Cliquer sur une province : drill-down vers les secteurs, les opérateurs de rang, les emplois - Afficher le **graphique Opérateurs** → **Secteurs** → **Conformité** (treemap) - Afficher la **timeline de conformité historique** : courbe remontant de 84 % il y a 6 mois à 91 % maintenant - Naviguer vers « Briefing audio » - Afficher une interface avec un bouton « Générer » - Dire : « Cliquez ici, et le système génère un résumé audio de 3 minutes, à écouter le matin en arrivant au bureau. »

- Appuyer sur Play : une voix franco-gabonaise synthétisée lit un briefing : > « Monsieur le Ministre, vendredi à 8 heures. Hier, 23 ATI ont été soumises, légèrement au-dessus de la médiane hebdomadaire. Trois non-conformités majeures détectées dans le secteur agroalimentaire, qui pourrait affecter 340 emplois si non réglées sous 14 jours. Deux appels de décision sont en attente de votre signature. Les provinces d'Ogooué-Ivindo et du Woleu-Ntem restent sous-représentées — proposer une mission terrain. À bientôt. » - Arrêter la lecture

À dire : « Vous êtes Ministre. Vous ne lisez pas 50 pages de rapport. Vous arrivez le matin, vous écoutez un résumé de 3 minutes. Tout ce que vous devez savoir pour prendre les bonnes décisions.

La PNPI ne vous submerge pas de chiffres — elle vous donne des signaux. Quand ça va bien, c'est vert. Quand il y a un risque d'emploi, c'est signalé en orange. Quand c'est critique, rouge.

Vous pouvez cliquer sur chaque KPI et creuser : pourquoi le délai est-il à 32 jours au lieu de 30 ? Quel secteur, quelle province ? Et vous changez les règles si vous le souhaitez. Tout ça, sans appeler quelqu'un. En trois clics.

Le briefing audio, c'est fait avec l'IA Claude d'Anthropic. C'est fiable, c'est en français, ça compile les données brutes en intelligence actuelle. »

Transition : « Maintenant, une ATI peut ne pas être conforme en bureaux. On doit aller vérifier sur le terrain. C'est le rôle de l'inspecteur. »

6:30–7:30 — INSPECTEUR : INSPECTION TERRAIN, PHOTOS, SIGNATURE

À l'écran : - Basculer sur un compte inspecteur (ou afficher l'app mobile si écran partagé) - Naviguer vers « Mes inspections à faire » - Afficher une inspection planifiée : nom opérateur, coordonnées GPS, checklist d'inspection (12 items) - Montrer l'app mobile (si disponible) avec GPS activé - Afficher une capture : inspecteur sur le terrain, app affiche « À 50 mètres du site » - Montrer la checklist sur l'app : - Conformité bâtiment (case à cocher) - Présence extincteurs (case à cocher) - État machines (case à cocher) - Sécurité des employés (photo requise) - Gestion déchets (photo requise) - Déclaration production vraie ? (validation croisée) - Cliquer sur « Ajouter photo » : montrer une galerie de 3-4 photos prises sur le terrain - Ajouter un commentaire libre : « Bâtiment bien entretenu, machines conformes, mais problème de drain côté sud — à signaler au gérant. » - Signer électroniquement l'inspection (signature sur écran tactile ou biométrie) - Appuyer sur « Envoyer » : statut → Inspection complétée - Notification auto : l'opérateur reçoit le rapport PDF - Afficher la **heatmap des inspections** côté Ministre : densité géographique, color-coding par statut

À dire : « L'inspecteur part avec l'app sur son téléphone. Pas de papier, pas de stylo. L'app sait où il doit aller, qu'est-ce qu'il doit vérifier, et si le site n'est pas au bon endroit — grâce au GPS — l'app lui dit.

Sur le terrain, il prend des photos, il note ce qu'il voit. L'app compile ça automatiquement en rapport PDF. À la fin de la journée, il signe, et tout est remontée à Libreville en 30 secondes.

Vous, Ministre, vous voyez une carte de toutes les inspections du mois. Vous voyez les trends : où est-ce qu'il y a le plus de non-conformités ? Quels secteurs posent problème ? Vous pouvez redéployer les inspecteurs dynamiquement. »

Transition : « Mais il y a des opérateurs qui ne sont pas d'accord avec la décision. Ils ont droit de recours. Ça aussi, c'est intégré. »

7:30–8:30 — WORKFLOW RECOURS, AUDIT TRAIL, TRAÇABILITÉ

À l'écran : - Naviguer vers « Gestion des recours » - Afficher une liste : 3 recours en attente, 2 acceptés, 1 rejeté - Ouvrir un recours : opérateur conteste le statut rejeté - Date du rejet - Raison du rejet (« Non-conformité capitale : capacité de production sous-déclarée ») - Lettre de recours de l'opérateur (texte librement saisi) - Pièces jointes (mémoire technique) - Cliquer sur « Historique complet » : afficher la timeline complète de l'ATI original - J+0 — Soumission par opérateur - J+2 — Instruction commencée, demande d'info - J+4 — Réponse opérateur - J+6 — Inspection approuvée - J+8 — Décision : rejet - J+10 — Recours déposé - **Chaque ligne indique qui a agi, quelle heure, signature numérique** - Montrer l'**audit trail complet** : un tableau détaillé montrant chaque action, chaque modification - Cliquer sur « Traçabilité données » : montrer la version historique des données (qui a modifié quoi et quand)

À dire : « Si un opérateur conteste une décision, on a l'historique complet. Qui a pris la décision, sur quelle base, quelles données, à quelle heure. Tout est horodaté, signé numériquement.

C'est **la traçabilité juridique** que vous ne pouviez pas avoir avec du papier. Si la décision est contestée devant le tribunal, vous avez la preuve que vous avez agi de bonne foi, en suivant le process, en toute transparence.

Ça protège aussi vos agents. Personne ne peut dire qu'on a pris une décision arbitraire — la PNPI le prouve scientifiquement. »

Transition : « Maintenant, tous ces dossiers, toutes ces données, elles sont **sensibles**. Le Gabon doit pouvoir les contrôler, les sécuriser, et les utiliser à bon escient. C'est ce que je vous montre maintenant. »

8:30–9:30 — OPEN DATA ANONYMISÉ, SÉCURITÉ, SOUVERAINETÉ

À l'écran : - Naviguer vers « Portail Open Data » - Afficher la page publique : graphiques anonymisés - Nombre d'ATI par secteur (pas d'opérateurs nommés) - Emplois industriels par

province (total, pas par entreprise) - Tendances conformité sur 12 mois (courbe) - Investissements déclarés par secteur (agrégé) - Comparaison CEMAC (si données disponibles) - Cliquer sur « Méthodologie » : montrer que les données sont anonymisées avec seuil **k-anonymity = 5** - Explication : « Aucun secteur avec moins de 5 entreprises n'est visible » - Exemple : si 3 opérateurs seulement dans le secteur mines, ce secteur n'apparaît pas - Afficher le **diagramme d'architecture sécurité** : - Données brutes dans PostgreSQL (chiffré au repos) - Accès contrôlé par JWT + 2FA - Chiffrement en transit HTTPS - Audit trail = table séparée, non modifiable - Hébergement ANINF (souveraineté garantie par contrat) - Backup S3 chiffré hors-site (récupération en catastrophe) - Afficher la **page de transparence** : - Version du code déployée - Date du dernier pentest de sécurité (1er mai 2026 — audit interne zéro vulnérabilité critique) - SLA de disponibilité (99,5 %) - Qui a accès à quoi (matrice RBAC publique)

À dire : « Vous me livrez vos données les plus sensibles — qui crée une usine, où, quel chiffre d'affaires. Vous avez le droit de savoir où elles vont.

Voici le portail. **Tout ce que nous publions est anonymisé.** Pas de noms, pas de NIF, pas de localisation précise. Juste les tendances : quel secteur crée le plus d'emplois, où est-ce qu'il y a des risques.

C'est de la transparence pour les citoyens, les investisseurs, les partenaires internationaux. Et c'est zéro risque pour vos opérateurs — on ne peut pas les identifier.

Sur la sécurité : j'ai fait un audit interne le 1er mai. Zéro vulnérabilité critique. Les données sont chiffrées, jour et nuit. L'accès est limité aux 6 rôles que j'ai décrits. Il y a un audit trail non effaçable — chaque consultation est notée.

Et les données restent au Gabon. C'est ici chez ANINF, pas chez un cloud américain. C'est votre souveraineté. »

Transition : « Maintenant, cette démo vous montre le système en prod idéal. Mais évidemment, dès demain il peut y avoir un bug. On a un plan B pour ça. »

9:30–10:00 — VIDÉO REMOTION 40s (OU PLAN B DÉMO)

À l'écran : - Si la démo a tenu bon jusqu'ici : lancer une **vidéo Remotion animée de 40 secondes** - Synthèse visuelle du workflow complet ATI (soumission → instruction → signature → inspection → recours) - Voix-off en français gabonais - Musique discrète instrumentale - Textes incrusté = KPIs clés - Dernière image : logo République Gabonaise + « PNPI — Souveraineté Numérique »

- **Alternative si démo casse** (wifi mort, bug app, etc.) :
- Dire : « Je vous montrais la démo en direct, mais on a un soucis réseau. Pas de problème. »

- Sortir une **clé USB** : « Voici deux vidéos pré-enregistrées, et trois PDFs détaillés par profil utilisateur. Vous pouvez les regarder à votre rythme ce soir. »
- Remettre la clé USB à la main
- Continuer la conversation : « Ça vous pose des questions ? »

À dire : « Voilà la PNPI en 10 minutes. C'est une plateforme qui **disparaît**. Elle est si facile à utiliser que personne ne doit penser à la technologie — il y a juste le métier qui s'écoule.

Avant, traiter une ATI prenait 120 jours et du papier. Maintenant c'est 30 jours et du numérique. Avant, un opérateur devait venir à Libreville. Maintenant il clique de son village. Avant, vous n'aviez aucune visibilité. Maintenant c'est temps réel.

Trois questions pour nous ? »

3. CINQ QUESTIONS ANTICIPÉES DU CABINET — Q/R PRÉPARÉES

Q1. Pourquoi 28 M FCFA/an et pas moins, ou un développement par l'ANINF ?

Réponse — 60 secondes max :

« La plateforme telle qu'elle existe a coûté 8 000 heures de travail — c'est équivalent à 4 années d'un ingénieur senior. À la grille de consultant IT au Gabon (200–400 K FCFA/jour), ça représente 80–120 millions en frais de développement.

Je vous l'offre. Zéro franc pour le développement.

Ce que je demande — 28 millions par an — c'est uniquement les frais d'**exploitation, maintenance et évolution**. Ça couvre : l'hébergement ANINF (6 M), la sécurité (audit, pentest), les crédits IA, le support opérationnel, et une journée-homme par mois pour l'évolution.

C'est 15–25 % du coût d'investissement en année, ce qui est le standard industriel. Si vous aviez passé un marché public pour développer ça, vous payeriez 120 M pour le dev + 25 M/an de maintenance. Ici, vous payez 28 M/an seulement.

Quant à l'ANINF — c'est un excellent partenaire. Mais l'ANINF n'a ni les ressources ni la mandate pour concevoir une plateforme métier industrielle. On la sollicite plutôt pour **opérer et héberger** ce que j'ai conçu. C'est un partage de rôles. »

Q2. Vous gardez la propriété intellectuelle. Qu'est-ce qui empêche que vous vendiez ça à un autre pays demain et qu'on vous échappe ?

Réponse — 60 secondes max :

« C'est la bonne question. Voici la réponse : la **convention de droit d'usage perpétuel et exclusif**.

Concrètement : le Gabon a tous les droits d'utilisation de la PNPI à **perpétuité** — c'est-à-dire à jamais. Et **exclusif sur le territoire gabonais** — c'est-à-dire que si je la porte au Cameroun, l'instance camerounaise sera différente, seule, sans concurrence.

Je conserve la PI pour une seule raison : pouvoir l'adapter et la vendre à d'autres pays CEMAC. Pas pour faire de l'argent facile, mais pour que chaque version nationale soit durable — chaque pays finance sa propre instance.

Mais je ne peux **pas** vendre à un autre pays une plateforme qui clonerait exactement le Gabon. La loi vous le permet pas non plus — vous avez un droit exclusif. Et si je le faisais quand même, vous avez le code source en escrow chez un notaire : vous reprenez tout, vous la maintenez vous-même.

Donc : l'État gabonais a une **assurance complète**. La PI chez moi, c'est une commodité technique pour l'expansion CEMAC, mais ça ne vous fragilise pas. C'est l'inverse — ça rend le Gabon plus fort régionalement. »

Q3. Vous êtes seul. Que se passe-t-il si vous tombez malade, partez à l'étranger, ou ne maintenez plus la plateforme ?

Réponse — 60 secondes max :

« C'est le risque le plus important, je ne le cache pas. Vous lirez ça dans mon registre de risques (cf. `docs/architecture/risk-register.md`) : c'est le risque R-022, score 20/25 — le plus élevé.

Mais j'ai des plans de mitigation :

Un : tout est documenté. Le code source, les procédures, les décisions architecturales, les runbooks. Un développeur gabonais senior peut reprendre en moins de 4 semaines.

Deux : j'écris une clause contractuelle d'obligation de **transfert de compétence**. Si je deviens indisponible, j'ai 30 jours pour former un tiers gabonais agréé à reprendre. Les coûts sont dans la convention.

Trois : dès l'année 2, si ça marche, j'embauche un deuxième développeur gabonais. Vous êtes plus de 1. Le bus factor devient 2, puis 3.

Quatre : le code est en séquestre chez un notaire. Si je disparaissais complètement, l'État y accède et peut engager qui il veut pour la reprendre.

Donc oui, je suis seul **aujourd'hui**. Mais la convention vous protège contre ce risque. Et franchement, c'est dans mon intérêt aussi — si je disparaissais, je ne suis payé plus. »

Q4. Qu'est-ce que vous proposez en termes de calendrier de déploiement et de formation des agents ?

Réponse — 60 secondes max :

« Le plan est dans `docs/architecture/plan-mise-en-prod-j0-j90.md` . Voici le résumé :

J0 — Signature de la convention.

J+1 à J+7 : Cadrage technique — provisioning ANINF, création du domaine `pnp1.gov.ga` , déploiement en pré-production.

J+8 à J+15 : Pentest de sécurité externe. Je remède les trouvailles. Vous avez le report zéro vulnérabilité critique.

J+16 à J+30 : Formation — 3 jours par groupe métier. - 1 journée pour les admin (4 personnes) - 1 journée pour les instructeurs (12 personnes) - 1 journée pour les inspecteurs (8 personnes) - 1 journée pour le Cabinet et les directeurs (6 personnes) - 1 journée pour les opérateurs (focus guichet)

J+31 à J+60 : Bascule progressive. Démarrage avec 10 opérateurs pilotes, validation du workflow réel.

J+60 : Ouverture officielle — communication publique, tous les utilisateurs activés.

J+60 à J+90 : Phase pilote intensifiée, appels au Ministère chaque matin, ajustements en temps réel.

J+90 : Retour d'expérience formel, bilan des 30 premiers jours, liste des améliorations J+3 à J+6 mois.

Le tout documenté dans un plan de gouvernance. »

Q5. Quelles garanties de sécurité et de souveraineté des données ? Les données restent au Gabon ?

Réponse — 60 secondes max :

« Oui, les données restent au Gabon — c'est contractuel.

Sécurité : - **Chiffrement au repos :** PostgreSQL avec chiffrement de volume, backups S3 chiffré. - **Chiffrement en transit :** tout en HTTPS TLS 1.3. - **Authentification :** JWT + 2FA TOTP, sessions courtes (8h). - **Audit trail :** journal complet et non modifiable de chaque action. - **Contrôle d'accès :** RBAC strict — 6 rôles, aucun chevauchement.

J'ai fait un audit interne le 1er mai : zéro vulnérabilité critique (cf. `docs/audit-securite-interne/00-rapport-audit-interne.md`). Un pentest externe indépendant est prévu J+10.

Souveraineté : - **Hébergement :** ANINF Libreville, données physiquement au Gabon. -

Propriété des données : article 5.4 du protocole — l'État gabonais est propriétaire de 100 % des données. Je n'ai aucun droit d'usage commercial. - **Portabilité :** vos données sont exportables en standard (JSON, CSV, SQL), pas de vendor lock-in. - **Continuité :** plan PCA (plan de continuité d'activité) avec réplique off-site ANINF, RTO < 4h, RPO < 1h.

Conformité : - Loi N°026/2017 (protection données Gabon) - Loi N°042/2021 (transactions électroniques) - Compatible RGAA 4.1 (accessibilité)

Vous avez une **plateforme gabonaise, pour les données gabonaises, opérée par l'État gabonais**. Zero dépendance étrangère sur le métier. »

4. TROIS COMPARATIFS INTERNATIONAUX

Référence 1 — ESTONIA X-ROAD (2000 - Estonie)

Contexte : Estonie, État-nation baltique en transformation numérique.

Ce qui a été fait : Plateforme d'interopérabilité gouvernementale liant 800+ organisations (ministères, municipalités, entreprises, justice, santé). Chaque service peut se connecter et échanger des données de façon sécurisée sans duplication. Citoyen crée son entreprise en 4 heures. Signature numérique obligatoire. Audit trail complet.

Coût / Modèle : Investi 250 M USD en 20 ans (1997–2017). Financé par le budget IT d'État, amortissement long terme. Pas d'appel d'offres : construction interne avec expertise propre.

Ce que la PNPI emprunte : Approche **souveraine d'abord**. Les Estoniens n'ont pas acheté chez Siebel ou SAP — ils ont construit. Traçabilité complète (chaque action audit). Gouvernance de données stricte (qui accède à quoi).

Ce que la PNPI rejette : Le modèle estonien suppose un État riche capable d'investir 250 M USD. Le Gabon n'a pas ce budget. La PNPI propose plutôt un **partenariat avec un créateur privé** (moi) capable de assurer le déploiement et la maintenance pour un coût maîtrisé.

Référence 2 — FRANCE API ENTREPRISE (2014 - France)

Contexte : France, chantier "État Plateforme" pour simplifier les démarches administratives.

Ce qui a été fait : API centrale fédérant les données de la Douane, l'INPI, l'INSEE, la DGI, la Banque de France. Une start-up ou une PME fait une démarche administrative une seule fois, les données circulent entre les ministères sans ressaisie. Un certificat numérique pour tous les services.

Coût / Modèle : Investi 150 M EUR sur 10 ans (2014–2024). Financé par le budget IT d'État, management interne (DINUM — Direction Interministérielle du Numérique).

Ce que la PNPI emprunte : L'idée que les **données doivent circuler** et ne doivent pas être resaisies. Interopérabilité comme philosophie. Open Data public (anonymisé). Une plateforme qui fait le lien entre plusieurs acteurs (opérateurs, instructeurs, inspecteurs, décideurs).

Ce que la PNPI rejette : Le modèle français suppose une architecture décentralisée (chaque ministère gère son API). Le Gabon n'a pas encore cette maturité. La PNPI propose plutôt une **plateforme monolithique** centralisée, plus simple à opérer au démarrage, mais capable d'exposer des APIs plus tard (pour l'interconnexion DGI, RCCM, etc.).

Référence 3 — RWANDA IREMBO (2019 - Rwanda)

Contexte : Rwanda, pays en développement, ambition de transformation numérique rapide.

Ce qui a été fait : Guichet unique numérique pour les démarches administratives (cartes d'identité, licences commerciales, permis de conduire, etc.). Citoyen se connecte, fait sa demande, paie en ligne, reçoit son certificat en PDF. API pour les communes.

Coût / Modèle : Investi 80 M USD sur 5 ans. Modèle de partenariat public-privé : gouvernement rwandais a engagé une start-up locale + expertise internationale. Forfait annuel pour la maintenance.

Ce que la PNPI emprunte : Le modèle PPP (partenariat public-privé) adapté aux pays en développement. **Une seule plateforme**, pas plusieurs. **Guichet unique** qui simplifie la vie des citoyens. Paiement en ligne. Certificats dématérialisés. Impact mesuré et communiqué.

Ce que la PNPI rejette : Irembo couvre les démarches grand public (cartes, licences). La PNPI couvre un métier métier très spécialisé (industrie, contrôle de conformité). Irembo s'appuie sur Ericsson et Huawei pour l'infra. La PNPI s'appuie sur ANINF (local).

Synthèse : Ces trois modèles montrent que **la souveraineté numérique n'est pas un luxe de pays riche**. L'Estonie, la France et le Rwanda ont tous investi lourdement, à des échelles différentes, parce que **la digitalisation du service public est un enjeu stratégique**. La PNPI emprunte les meilleures pratiques des trois : souveraineté d'abord (Estonie), interopérabilité et data-sharing (France), modèle PPP adapté (Rwanda), avec une posture de **transparence locale** qui est gabonaise.

ANNEXE — BOUTON DE SECOURS DÉMO

Si la démonstration technique plante (problème WiFi, bug applicatif, serveur injoignable), **restez calme** et appliquez le plan de fallback :

1. Arrêter la démo, dire : « Aucun problème, on a un plan B. »
2. Sortir la clé USB préparée contenant : - VIDEO_REMOTION_40s.mp4 — démonstration pré-enregistrée fluide - PDF_Guide_Operateur.pdf — guide par rôle, illustré - PDF_Guide_Instructeur.pdf - PDF_Guide_Ministre.pdf - PDF_Architecture_Technique.pdf
3. Dire : « Voici une vidéo pré-enregistrée — aucun risque. Et trois PDFs détaillés que vous pouvez lire tranquille ce soir. »
4. Remettre la clé en main propre.
5. Continuer la conversation sur les Q/R, sans perdre le fil du pitch.

Durée perte : 30 secondes max. Impact sur persuasion : minimal (le PDF c'est professionnel et fiable).

Document préparé par : Jean Baptiste MBA NDONG **Date :** 2 mai 2026 **Version :** 1.0 — Audience ministérielle **Statut :** Confidentiel — Préparation entretien Ministre

À relire 30 minutes avant l'audience. À apprendre par cœur pour le pitch d'ouverture (90s).

Cadrage stratégique — Positionnement avant l'audience ministérielle

*Document interne · Préparation entretien Cabinet Ministre de l'Industrie · Avril 2026 Auteur : Jean Baptiste
MBA NDONG (concepteur PNPI)*

1. La question fondamentale

Est-ce que je me présente comme fournisseur, partenaire institutionnel, ou futur agent public ?

Cette décision conditionne tout le reste : structure légale, modèle de revenus, contrat, propriété intellectuelle, durée. **Il faut la trancher avant l'audience.**

2. Trois postures possibles

Posture A — Prestataire (entreprise privée → Ministère)

Vous créez une SARL/SA, vous facturez la PNPI au Ministère via un marché public.

AVANTAGE	INCONVÉNIENT
Indépendance totale, vous gardez la PI	Marché public = appel d'offres potentiel (vous serez challengé)
Capacité à servir d'autres clients (CEMAC)	TVA, obligations fiscales, gestion
Modèle scalable si la PNPI essaime	Trésorerie : délais paiement État = 90-180 jours
Vous restez maître de la roadmap	Risque de non-renouvellement chaque année

Profil idéal : si vous voulez construire **une entreprise tech gabonaise** avec la PNPI comme produit phare.

Posture B — Partenaire institutionnel (don / convention de partenariat)

Vous transférez la propriété de la PNPI au Ministère contre une convention pluri-annuelle qui couvre votre rétribution comme **expert technique**.

AVANTAGE	INCONVÉNIENT
Statut symbolique fort : « citoyen au service de l'État »	Vous perdez la PI
Pas d'appel d'offres (don ≠ marché)	Rétribution alignée sur grille de la fonction publique (modeste)
Sécurité contractuelle : pluri-annuelle	Difficile de monétiser ailleurs
Reconnaissance publique du Président / Ministre	Capacité d'évolution liée au budget de l'État

Profil idéal : si vous cherchez **stabilité + reconnaissance + impact public** plus que rémunération maximale.

Posture C — Hybride (recommandée)

Vous créez une structure (SARL ou Association reconnue d'utilité publique) qui : - Cède **un droit d'usage perpétuel** à l'État Gabonais (gratuit ou symbolique) - Conserve **la propriété intellectuelle** + droit de licence pour les autres pays CEMAC - Facture au Ministère **uniquement la maintenance, l'évolution et le support** (forfait annuel) - Reçoit éventuellement une dotation ANINF / FAFI / ARSI pour développement

AVANTAGE	INCONVÉNIENT
Le Ministère a la sécurité d'usage perpétuel = pas d'appel d'offres	Structure juridique plus fine à monter
Vous gardez la PI = monétisable en CEMAC	Négociation un peu plus complexe à l'audience
Modèle scalable + impact public + revenus stables	Demande un avocat / fiscaliste pour la convention
Permet de basculer vers SaaS multi-tenant Cameroun/Congo plus tard	

Profil idéal : équilibre impact public + viabilité économique. C'est la voie que je recommande.

3. Ma recommandation

Posture C (Hybride) pour ces raisons :

1. **Le Ministre a personnellement validé l'audience** (30.03.26) → il vous voit comme un **citoyen-partenaire**, pas un fournisseur lambda. Capitaliser cette posture.
2. **Vous êtes solo** → posture A demande plus de bras. Posture B vous transforme en agent.
3. **Le Gabon n'a pas de track-record de marchés publics IT au million de FCFA pour solo dev** → mieux vaut un cadre conventionnel sui generis.
4. **CEMAC est l'option de scale** → la posture B vous l'interdit, la C la préserve.
5. **C'est ce qui rassure le Cabinet** : « pas un risque pour le contribuable » + « pas de captation par un privé ».

4. Position à tenir à l'audience

« Monsieur le Ministre, j'ai conçu seul cette plateforme pour le Gabon. Je propose de céder à l'État un droit d'usage perpétuel et exclusif sur le territoire gabonais. En retour, je sollicite un cadre conventionnel pluri-

annuel qui couvre la maintenance, l'évolution et la formation des agents. Je conserve la propriété intellectuelle pour pouvoir, demain, valoriser ce modèle dans la sous-région CEMAC sous l'égide du Gabon — qui en sera reconnu comme l'État pionnier. »

Cette phrase positionne : - **Don d'usage** = générosité civique - **Convention de maintenance** = viabilité économique - **PI préservée** = ambition d'expansion - **Sous l'égide du Gabon** = soft-power national, flatte le Ministère

5. Sujets à anticiper (questions probables du Cabinet)

QUESTION	VOTRE ANGLE DE RÉPONSE
« Combien ça coûte au final ? »	Cf. document 02-pricing-pnpi.md — entre 18 et 36 M FCFA / an de maintenance
« Qu'est-ce qui empêche un autre dev de faire pareil ? »	Le code source restera la propriété conventionnelle. Vous offrez l'expertise.
« Avez-vous une entreprise ? »	« Non, j'ai conçu cela en solo. Je suis prêt à structurer ma société dans les prochaines semaines selon les attentes du Ministère. »
« Pourquoi pas un appel d'offres ? »	« La plateforme existe déjà. L'appel d'offres serait pour la créer ; là, l'État reçoit un actif clés-en-main. »
« Qui prend en charge l'hébergement ? »	« Je recommande l'ANINF — souveraineté garantie. À défaut, OVH Dakar / Hetzner Africa. »
« Que se passe-t-il si vous disparaissiez (santé, accident) ? »	« Le code source est sous séquestre numérique chez un avocat. Le Ministère a accès complet. Je documente tout. »
« Combien de temps pour passer en production ? »	« 4 semaines : provisioning, hébergement souverain, audit pentest indépendant, formation. »
« Pouvez-vous former nos agents ? »	« Oui. J'ai déjà préparé 6 guides PDF par rôle, accessibles dans la plateforme. Sessions 2 h par groupe métier. »

6. Décisions à acter avant l'audience

- ☐ Trancher la posture (A / B / C) — recommandation : C
 - ☐ Préparer la structure légale (SARL ou Association) → rendez-vous notaire / avocat
 - ☐ Calculer les coûts d'hébergement souverain ANINF (devis informel)
 - ☐ Préparer un dossier remis en main propre : présentation HTML imprimée + clé USB avec démo
 - ☐ Préparer un compte démo Ministre dédié (pas le compte générique seed)
 - ☐ Imprimer 3 copies du dossier (Cabinet, DGI, vous)
 - ☐ Préparer un message LinkedIn / X de remerciement post-audience (visibilité)
-

Ce document est une note interne de préparation. Il ne sera pas remis tel quel au Cabinet.

Modèle de pricing PNPI — Pour l'audience ministérielle

Document de cadrage économique · à utiliser comme support à la conversation, pas comme document de signature

1. Le contexte qui dicte les chiffres

VARIABLE	VALEUR DE RÉFÉRENCE GABON
Salaire ingénieur senior à Libreville	1.5 – 3 M FCFA / mois
TJM consultant IT senior	200 – 400 K FCFA
Coût annuel hébergement souverain ANINF (estimation)	4 – 8 M FCFA
Budget moyen IT Ministère technique	200 – 800 M FCFA / an
Marché public IT Gabon (taille typique)	30 – 300 M FCFA

Cible psychologique : un montant qui ne soit ni dérisoire (le Cabinet sous-estime alors la valeur) ni excessif (rejet immédiat). Zone : 15–40 M FCFA / an.

2. Trois lignes d'offre (à présenter)

Ligne 1 — Cession et droit d'usage perpétuel pour l'État Gabonais

ITEM	MONTANT	COMMENTAIRE
Cession du droit d'usage perpétuel	0 FCFA (don)	Le geste fort. Vous offrez la plateforme à l'État.
Documentation, code source, transfert	Inclus	Mise en séquestre numérique chez avocat
Formation initiale des 6 profils	Inclus (3 jours)	Sessions par groupe métier

Valeur perçue : ~80–120 M FCFA (le coût équivalent si l'État avait passé un marché public pour développer la plateforme).

Effet : positionne la générosité civique. Le Cabinet voit que vous n'êtes pas là pour racketter.

Ligne 2 — Convention pluri-annuelle de maintenance et d'évolution (RECURRENT)

C'est la ligne qui finance votre vie. Trois variantes selon ambition :

Option Standard — 18 M FCFA / an (1.5 M / mois)

Couvre : - Hébergement souverain (ANINF ou équivalent) + supervision - Maintenance correctrice (bugs critiques sous 4h, autres sous 48h) - 2 montées de version mineures par an - Support utilisateur 8h-17h jours ouvrés - Hotline directe pour le Cabinet (Ministre, DG, DGA) - Rapports trimestriels d'usage

Option Avancée — 28 M FCFA / an (2.3 M / mois) — recommandée

Tout le Standard + - 1 montée de version majeure par an (nouvelles fonctionnalités stratégiques) - 1 jour-homme par mois d'évolution sur mesure (24 jours/an) - Module IA (chat assistant + prédictions) : crédits Anthropic inclus jusqu'à 200 USD/mois - Backup off-site (S3 chiffré) + plan de continuité d'activité - Audit pentest externe annuel

Option Premium — 42 M FCFA / an (3.5 M / mois)

Tout l'Avancé + - App mobile inspecteurs (Android + iOS) maintenue - 3 jours-hommes par mois d'évolution sur mesure - Intégration Registre du Commerce + DGI (interfaces) -

Ligne 3 — Prestations à la demande (HORS FORFAIT)

PRESTATION	TJM	CAS D'USAGE
Développement nouveau module métier	350 K FCFA / jour	Ex. module gestion des subventions
Audit / conseil stratégique	400 K FCFA / jour	Études de cadrage
Formation supplémentaire	250 K FCFA / jour	Sessions terrain pour inspecteurs
Migration / interconnexion système tiers	500 K FCFA / jour	API DGI, Trésor, Douanes

3. Argumentaire prix vs valeur

« Pour mettre en perspective : un consultant IT externe facturerait à l'État 60–120 M FCFA pour développer la plateforme telle qu'elle existe. Je vous l'offre. Je demande seulement les moyens de la maintenir vivante et de la faire évoluer. La maintenance d'un actif numérique vaut typiquement 15–25 % du coût d'investissement par an — c'est précisément la fourchette des 18–28 M FCFA. »

Comparables internationaux : - France : France-Connect pour Bercy → 6 M€ / an de maintenance - Maroc : Plateforme RNIE → 15 M MAD / an - Sénégal : SENELEC e-services → 80 M FCFA / an

→ La PNPI à 18-28 M FCFA est **compétitive et raisonnable** pour un Ministère.

4. Points de négociation prévisibles

LE CABINET POURRAIT DIRE	VOTRE RÉPONSE
« C'est cher »	« Le coût équivalent en marché public serait 5x supérieur. Nous parlons d'un actif national stratégique, pas d'un site vitrine. »
« On peut faire moins ? »	Option Standard à 18 M. Acceptez si vous voyez un autre Ministère adopter dans la foulée.
« Comment savoir que vous tenez l'engagement ? »	« Convention assortie de SLA contractuels avec pénalités. Audits trimestriels indépendants. »
« Et la souveraineté du code ? »	« Code en escrow chez un notaire, accessible à l'État en cas d'incident. »
« Et si vous faites faillite / partez ? »	« Convention de transfert de compétence à un tiers gabonais agréé. Documentation exhaustive prête. »
« 28 M c'est trop pour la première année »	Proposez : Standard 18 M année 1, Avancé 28 M dès l'année 2 si KPIs satisfaisants

5. La règle d'or à l'audience

Ne donnez aucun chiffre spontanément. Si on vous demande, donnez **la fourchette 18–42 M selon le périmètre** et précisez : « Ce sont des ordres de grandeur. Je serai ravi de présenter une proposition détaillée à votre directeur de cabinet ou au DAF dans les 7 jours. »

Cela vous donne : 1. Le temps de calibrer après l'audience selon les signaux reçus 2. La possibilité d'ajuster en fonction du DG pressenti pour piloter le dossier 3. L'aura d'un professionnel qui ne brade pas

6. Calcul de viabilité personnelle (interne, à ne pas montrer)

Hypothèse Option Avancée 28 M FCFA / an :

POSTE	MONTANT ANNUEL
Infra (ANINF/OVH + S3 + monitoring)	6 M
Crédits Anthropic / OpenAI / Claude	2.5 M
Pentest annuel	3 M
Avocat / fiscal / structure	1 M
Marges de manœuvre / formation	1.5 M
Total charges	14 M
Reste pour rémunération concepteur	14 M / an = 1.17 M / mois

→ Couvre votre vie + vous laisse la marge pour le développement CEMAC.

Hypothèse Option Premium 42 M / an :

Charges similaires +5 M (app mobile, signature qualifiée) = 19 M. Reste : **23 M / an = 1.9 M / mois**. Confortable + capacité d'embauche.

7. Si pivot CEMAC (horizon 18 mois)

Si après 12-18 mois la PNPI tourne au Gabon, vous pouvez : - Démarcher Cameroun / Congo / Tchad / Centrafrique / Guinée éq. - Modèle SaaS multi-tenant à 12-20 M FCFA / pays / an - 4 pays = +60 M FCFA récurrents - Revenu total possible : 90-110 M FCFA / an avec 1 Gabon + 4 CEMAC

→ C'est ce qui justifie la **conservation de la PI** dans la posture C.

Note interne. Préparation audience ministérielle. NE PAS DIFFUSER tel quel.

Modèle financier PNPI — Projection 36 mois

Hypothèse de base : posture C (Hybride) · Convention pluri-annuelle · Option Avancée 28 M FCFA/an
Document interne. Tous les montants en FCFA sauf indication contraire.

1. Hypothèses de revenus (3 scénarios)

Scénario CONSERVATEUR (probabilité 60 %)

ANNÉE	REVENU GABON	REVENU CEMAC	TOTAL
Année 1 (M1-M12)	18 M (Standard, démarrage)	0	18 M
Année 2	22 M (passage Avancé partiel)	0	22 M
Année 3	28 M (Avancé)	0	28 M

Scénario CENTRAL (probabilité 25 %)

ANNÉE	REVENU GABON	REVENU CEMAC	TOTAL
Année 1	28 M (Avancé direct)	0	28 M
Année 2	28 M	12 M (1er pays CEMAC : Cameroun)	40 M
Année 3	32 M	24 M (2 pays CEMAC)	56 M

Scénario OPTIMISTE (probabilité 15 %)

ANNÉE	REVENU GABON	REVENU CEMAC	TOTAL
Année 1	28 M	0	28 M
Année 2	32 M	24 M (2 pays)	56 M
Année 3	42 M (Premium)	60 M (4 pays)	102 M

2. Charges récurrentes (par an)

POSTE	ANNÉE 1	ANNÉE 2	ANNÉE 3	NOTES
Infrastructure cloud				
Serveur prod (ANINF / OVH Dakar)	4 M	4.5 M	5 M	scale-up à mesure
Storage S3 / MinIO + backups	1 M	1.5 M	2 M	rétenion 30j puis archivage
Domaine + HTTPS	0.1 M	0.1 M	0.1 M	Let's Encrypt gratuit
Services tiers				
Crédits Anthropic / Claude	1.8 M	2.4 M	3 M	chat assistant + IA reco
SMTP transactionnel	0.4 M	0.6 M	0.8 M	SendGrid ou AWS SES
Monitoring (Grafana Cloud, Sentry)	0.6 M	0.8 M	1 M	
Sécurité & conformité				
Pentest annuel externe	3 M	4 M	5 M	obligatoire pour ministériel
Audit ISO 27001 (préparation)	0	5 M	0	une fois sur 3 ans
Structure				
Avocat / fiscal / structure légale	1.5 M	1 M	1 M	création + gestion
Comptabilité (cabinet ext.)	1.2 M	1.5 M	1.8 M	
Assurance RC pro	0.8 M	0.9 M	1 M	
Outils dev				
GitHub Pro + CI minutes	0.3 M	0.4 M	0.5 M	

POSTE	ANNÉE 1	ANNÉE 2	ANNÉE 3	NOTES
IDE / licences	0.2 M	0.3 M	0.3 M	
Marketing / déplacements				
Site vitrine + branding	0.5 M	0.3 M	0.3 M	
Déplacements CEMAC (S2/S3)	0	2 M	4 M	démarches Cameroun, Congo
TOTAL CHARGES	15.4 M	25.3 M	25.8 M	

3. Compte d'exploitation simplifié — Scénario CENTRAL

	ANNÉE 1	ANNÉE 2	ANNÉE 3
Revenus	28.0	40.0	56.0
Charges (cf. ci-dessus)	-15.4	-25.3	-25.8
EBE avant rémunération	12.6	14.7	30.2
Rémunération concepteur (vous)	-12.0	-14.0	-22.0
EBE final	0.6	0.7	8.2
Réserve / investissement	0.6	0.7	8.2

→ En **Année 3**, la PNPI dégage 8 M de réserve qui peut financer une 1^{re} embauche (junior dev ou ops).

4. Trésorerie — points d'attention

Risque : délai paiement public

L'État Gabonais paie typiquement à **60–180 jours** sur facture. Avec 28 M annuels facturés trimestriellement (7 M / trimestre), un retard de 90 jours = besoin de fonds de roulement de **14 M minimum**.

Solution : négocier dès la convention : - Paiement d'avance trimestriel (50% à T0, 50% à T+45 jours) - Pénalité de retard automatique au-delà de 60 jours - Possibilité de cession Dailly à une banque locale (BICIG, BGFI) si la convention est ferme

Besoin de fonds de roulement initial

POSTE	MONTANT
Trésorerie 6 mois charges (15.4 M / 12 × 6)	7.7 M
Provision délai paiement (1 trimestre)	7.0 M
Caution éventuelle marché public	2.0 M
Apport initial nécessaire	~17 M

Sources possibles : - Apport personnel (épargne) - Prêt bancaire (BGFI / Ecobank ont des produits PME tech) - ANPI-Gabon (Agence Nationale de Promotion des Investissements) — subvention possible - Concours / programmes (Orange Digital Center, Africa Innovation Challenge) - Avance sur première convention (négociable)

5. Structure légale recommandée

Option A — SARL classique

- Capital min. 1 M FCFA
- Coût création ~500 K FCFA (notaire + greffe + RCCM)
- Délai 4–6 semaines
- IS taxe normale (30 %)
- Régime fiscal réel ou simplifié selon CA

Option B — SUARL (associé unique) — RECOMMANDÉE pour vous

- Solo founder = associé unique
- Capital min. 1 M FCFA
- Pas d'AGE/AGO obligatoire
- Coût et délai identiques à SARL
- Conformité OHADA

Option C — Association reconnue d'utilité publique

- Pas d'IS si activité non lucrative
- Mais : difficile à utiliser comme prestataire facturant
- À écarter pour ce cas

→ **Décision recommandée** : SUARL « PNPI Gabon » ou « MBA Industrial Tech », associé unique = vous.

6. Variantes selon l'audience

Si le Cabinet propose un statut d'agent contractuel au sein de l'ANINF

- Salaire grille fonction publique cadre A : ~1.2 M FCFA/mois brut = 14.4 M/an
- Avantages : sécurité de l'emploi, statut, retraite
- Inconvénients : capacité limitée pour CEMAC, perte de la PI, plafond salarial
- **À refuser poliment** sauf si proposition d'un poste haut (Directeur, Chargé de mission Ministre)

Si le Cabinet propose un partenariat mixte ANPI + Ministère

- Convention pluri-annuelle de 24-36 mois renouvelable
- Cofinancement ANPI sur la création / scale-up CEMAC
- **À accepter avec engagement de KPIs clairs**

Si le Cabinet propose une acquisition de la PNPI par l'État

- Évaluation du code source ~50–80 M FCFA (forfait one-shot)
- Vous devenez consultant freelance auprès du Ministère
- Avantages : cash immédiat

- Inconvénients : perte CEMAC, dépendance à un client unique
- **À négocier seulement si montant $\geq$ 80 M FCFA + contrat consultant 3 ans à 18 M/an**

7. Indicateurs de succès à proposer dans la convention

KPI	CIBLE ANNÉE 1	CIBLE ANNÉE 2	CIBLE ANNÉE 3
Disponibilité plateforme (uptime)	$\geq 99.0 \%$	$\geq 99.5 \%$	$\geq 99.9 \%$
Délai moyen traitement ATI	-20 % vs 2026	-35 %	-50 %
Nombre d'utilisateurs actifs	50	200	500
Volume ATI traités / an	200	500	1000+
Taux satisfaction agents (NPS)	≥ 30	≥ 50	≥ 70
Incidents critiques résolus < 4h	$\geq 90 \%$	$\geq 95 \%$	$\geq 98 \%$
Données ouvertes publiées	Mensuel	Hebdo	Quotidien

8. Synthèse 3-points pour l'audience

1. **« Je vous propose 28 M FCFA / an pour maintenir et faire évoluer une plateforme dont la valeur d'investissement équivalent serait 5x supérieure. »**
2. **« En 3 ans, le ratio coût/valeur est démontré : 84 M FCFA d'investissement public total contre 200+ M FCFA de coût alternatif. »**
3. **« Je conserve la propriété intellectuelle pour pouvoir faire rayonner ce modèle dans la sous-région CEMAC, à votre nom et à celui du Gabon. Aucun coût additionnel pour le contribuable gabonais. »**

Note interne. Ne pas distribuer. Utiliser comme aide-mémoire pour l'audience.

PROTOCOLE D'ACCORD

entre

Le Ministère de l'Industrie et de la Transformation Locale République Gabonaise représenté par Monsieur le Ministre, ou son représentant dûment habilité, ci-après dénommé « **le Ministère** »,

et

Monsieur Jean Baptiste MBA NDONG Citoyen gabonais, demeurant à Libreville agissant en son nom propre ou pour le compte de la société à constituer dénommée **PNPI Gabon S.U.A.R.L.** (ou dénomination équivalente) ci-après dénommé « **le Concepteur** »,

PRÉAMBULE

Considérant la volonté du Ministère de moderniser la délivrance des Agréments Techniques Industriels et le pilotage de la politique industrielle nationale ;

Considérant la conception, à titre privé et bénévole, par le Concepteur d'une plateforme numérique souveraine, opérationnelle, dénommée **Plateforme Nationale de Pilotage Industriel** (ci-après « **la PNPI** »), couvrant l'ensemble du cycle de vie des Agréments Techniques Industriels, des inspections de conformité et du pilotage ministériel ;

Considérant l'audience accordée le 30 mars 2026 par Monsieur le Ministre au Concepteur, à l'issue de laquelle le principe d'un partenariat a été retenu ;

Considérant l'intérêt général de doter le Gabon d'un outil souverain, contrôlé par l'État, et la nécessité concomitante d'assurer la pérennité technique et fonctionnelle de la plateforme ;

Il est convenu et arrêté ce qui suit :

ARTICLE 1 — OBJET DU PROTOCOLE

Le présent protocole a pour objet de fixer les conditions dans lesquelles :

1. Le Concepteur cède au Ministère un **droit d'usage perpétuel et exclusif** de la PNPI sur le territoire de la République Gabonaise.
2. Le Ministère confie au Concepteur la **maintenance, l'évolution, l'hébergement et la formation** liés à l'exploitation de la PNPI.
3. Le Concepteur conserve la **propriété intellectuelle** du code source et du modèle, à l'effet d'en valoriser éventuelle dans la sous-région CEMAC, sans préjudice des droits du Gabon.

ARTICLE 2 — DROIT D'USAGE CÉDÉ AU GABON

2.1 Étendue

Le Concepteur cède au Ministère un droit d'usage **perpétuel, irrévocable et exclusif** sur le territoire gabonais, à titre **gracieux** (don d'usage civique).

2.2 Périmètre

Le droit d'usage couvre : - L'exploitation opérationnelle de la PNPI par tous les services du Ministère ; - L'accès aux données produites par les utilisateurs gabonais (qui demeurent propriété de l'État Gabonais) ; - Le droit d'effectuer des audits techniques par tout tiers mandaté par le Ministère ; - Le droit de demander une copie complète du code source à tout moment.

2.3 Code source en séquestre

Une copie complète et à jour du code source, de la documentation et des configurations sera déposée auprès d'un notaire ou d'une autorité de séquestre numérique mutuellement agréée. Le Ministère pourra y accéder sans restriction en cas de défaillance du Concepteur.

ARTICLE 3 — PRESTATIONS DU CONCEPTEUR

3.1 Maintenance corrective

- Bugs critiques (impact sur la décision ATI) résolus sous **4 heures ouvrées**.
- Bugs majeurs résolus sous **48 heures ouvrées**.
- Bugs mineurs résolus sous **15 jours ouvrés**.

3.2 Maintenance évolutive

- **Deux montées de version mineures** par an (corrections, optimisations).
- **Une montée de version majeure** par an (nouvelles fonctionnalités, périmètre négocié annuellement).
- **Vingt-quatre jours-hommes** par an d'évolution sur mesure, à activer sur demande du Ministère.

3.3 Hébergement et infrastructure

- Hébergement souverain (ANINF prioritaire, ou prestataire local agréé).
- Disponibilité cible : **99,5 %** par an.
- Sauvegardes automatiques quotidiennes avec rétention 30 jours.
- Plan de continuité d'activité documenté et testé annuellement.
- Audit de pénétration externe réalisé annuellement.

3.4 Formation et accompagnement

- Formation initiale des six profils utilisateurs : **trois jours**, sessions par groupe métier, dans les 30 jours suivant la signature.
- Documentation utilisateur complète (guides PDF par rôle, vidéos courtes, FAQ).
- Hotline dédiée pour le Cabinet : 8h–17h jours ouvrés, intervention dans l'heure.

3.5 Reporting

- Rapport mensuel d'usage (volumes, performances, incidents).
 - Rapport trimestriel d'évolution de la plateforme.
 - Restitution annuelle au Cabinet par le Concepteur en personne.
-

ARTICLE 4 — RÉTRIBUTION

4.1 Forfait annuel

Le Ministère s'engage à verser au Concepteur un forfait annuel de **vingt-huit millions de francs CFA (28 000 000 F CFA)**, hors taxes éventuelles, en contrepartie des prestations décrites à l'article 3.

4.2 Modalités de paiement

- Paiement trimestriel à terme échu.
- Échéance : 60 jours calendaires à compter de la réception de la facture.
- Pénalités de retard : taux légal majoré de 2 %, applicables au-delà de 90 jours.

4.3 Révision annuelle

Le forfait sera révisé annuellement selon trois critères cumulatifs : 1. Indice général des prix (gel possible, augmentation plafonnée à 5 % par an). 2. Atteinte des indicateurs de performance définis à l'annexe 1. 3. Évolution du périmètre fonctionnel négociée d'un commun accord.

4.4 Prestations hors forfait

Les développements, audits ou formations excédant le forfait sont facturés selon une grille de prix unitaires (annexe 2).

ARTICLE 5 — PROPRIÉTÉ INTELLECTUELLE

5.1 Réserve du Concepteur

Le Concepteur conserve l'intégralité des droits patrimoniaux et moraux sur le code source, l'architecture, la documentation technique, le savoir-faire, et la marque éventuelle « PNPI ».

5.2 Droit d'usage gabonais

Sur le territoire gabonais, le Ministère bénéficie d'un usage perpétuel, irrévocable, gratuit et exclusif tel que défini à l'article 2.

5.3 Diffusion sous-régionale

Le Concepteur conserve la liberté de proposer la PNPI, sous toute forme adaptée, aux États membres de la CEMAC ou à toute autre entité publique ou privée, en mentionnant le **Gabon comme État pionnier** et en respectant l'intégrité de l'architecture déployée au Gabon.

5.4 Données

Les données saisies, produites ou stockées dans la PNPI gabonaise demeurent la propriété pleine et entière de l'État Gabonais. Le Concepteur n'a aucun droit d'usage commercial sur ces données.

ARTICLE 6 — CONFIDENTIALITÉ ET SÉCURITÉ

Les Parties s'engagent au respect strict de la confidentialité de toute information non publique. Le Concepteur s'engage en particulier à : - Tenir confidentiels les noms, coordonnées et profils des opérateurs industriels. - Mettre en œuvre les mesures de sécurité conformes à la loi N°026/2017 sur la protection des données personnelles. - Notifier sans délai au Ministère toute violation suspectée ou avérée.

ARTICLE 7 — DURÉE ET RÉSILIATION

7.1 Durée

Le présent protocole est conclu pour une durée initiale de **trois (3) ans**, renouvelable par périodes de deux (2) ans par tacite reconduction sauf préavis de six mois.

7.2 Résiliation pour inexécution

En cas de manquement grave et persistant aux engagements de l'une des Parties, l'autre Partie peut, après mise en demeure restée sans effet pendant 60 jours, résilier le protocole.

7.3 Conséquences de la résiliation

- Le droit d'usage perpétuel reste acquis au Ministère.
- Le Concepteur remet à l'État l'intégralité des codes, configurations et données dans un délai de 30 jours.
- Le Concepteur reste tenu d'une obligation de conseil pendant 90 jours après la résiliation, dans la limite de 5 jours-hommes.

ARTICLE 8 — INDÉPENDANCE DES PARTIES

Le Concepteur est un partenaire indépendant. Aucune disposition du présent protocole ne saurait créer un lien de subordination, ni un contrat de travail, ni une coentreprise.

ARTICLE 9 — RÈGLEMENT DES DIFFÉRENDS

Les Parties s'efforceront de régler à l'amiable tout différend né de l'interprétation ou de l'exécution du protocole. À défaut d'accord dans les 60 jours, le différend sera porté devant les juridictions compétentes de Libreville, le droit gabonais étant seul applicable.

ARTICLE 10 — SIGNATURE ET ENTRÉE EN VIGUEUR

Le présent protocole entre en vigueur à la date de sa signature par les Parties.

Fait à Libreville, le

en deux exemplaires originaux,

POUR LE MINISTÈRE	POUR LE CONCEPTEUR
Le Ministre	Jean Baptiste MBA NDONG
(ou la société PNPI Gabon S.U.A.R.L.)	

ANNEXES

- **Annexe 1** — Indicateurs de performance (KPIs SLA, volumes, satisfaction)
 - **Annexe 2** — Grille de prix unitaires hors forfait
 - **Annexe 3** — Procès-verbal de réception fonctionnelle (à établir au démarrage)
 - **Annexe 4** — Plan de continuité d'activité
-

Note interne : ce protocole est un brouillon rédigé par anticipation. Il doit impérativement être relu et adapté par un avocat gabonais avant toute signature. Il sert de support à la conversation lors de l'audience pour démontrer la maturité de la démarche et la rigueur du Concepteur.

Version : v0.1 · Avril 2026 · Document confidentiel

Audit de sécurité interne préliminaire — PNPI

Document interne · Pentest automatisé pré-audience ministérielle · 1er mai 2026 Auteur : Jean Baptiste MBA NDONG (concepteur PNPI) Périmètre : Plateforme Nationale de Pilotage Industriel (backend FastAPI + frontend Next.js)

1. Synthèse exécutive

Cet audit interne **préliminaire** vise à identifier les vulnérabilités connues de la PNPI avant l'audience ministérielle, en complément du futur audit externe humain prévu post-signature de la convention. Il s'inscrit dans une démarche de transparence et de **due diligence** vis-à-vis du Ministère de l'Industrie.

Méthodologie

5 outils de référence ont été exécutés sur le code source figé au commit `e5a38ce` :

OUTIL	PÉRIMÈTRE	TYPE
<code>pip-audit</code> 2.x	71 dépendances Python (<code>backend/requirements.txt</code>)	CVE / advisories
<code>npm audit --production</code>	462 dépendances Node (<code>frontend/package.json</code>)	CVE / advisories
<code>bandit</code> 1.x	20 563 lignes Python (<code>backend/app/</code>)	AST scan, anti-patterns
<code>semgrep</code> 1.161 (p/python, p/typescript, p/owasp-top-ten)	411 fichiers backend + frontend	Pattern matching OWASP
OWASP ZAP baseline scan	60 endpoints <code>/api/*</code>	DAST runtime (différé — voir §6)

Verdict global

Niveau de risque résiduel : FAIBLE à MODÉRÉ.

- Aucune vulnérabilité **critique** (RCE, injection SQL exploitable, contournement d'auth).
- 1 vulnérabilité **élevée** (Next.js 14.2.x DoS Image Optimizer) — **correctif disponible**.
- 4 vulnérabilités **modérées** (python-jose 3.3.0 JWT bomb + algorithm confusion) — **correctif disponible**.
- 26 alertes **bandit** (24 low, 2 medium) — **toutes faux positifs ou acceptables après revue**.
- 2 alertes **semgrep** — **1 faux positif, 1 hygiène de configuration**.

Aucun blocage avant audience. Les correctifs proposés tiennent en moins de 4 heures de travail (mises à jour mineures + revue de configuration).

2. Vulnérabilités CVE — dépendances

2.1 Backend Python (pip-audit)

PACKAGE	VERSION ACTUELLE	CVE	SÉVÉRITÉ	FIX
python-jose	3.3.0	CVE-2024-33664 (PYSEC-2024-233) — JWT bomb DoS	Modérée	3.4.0
python-jose	3.3.0	CVE-2024-33663 (PYSEC-2024-232) — Algorithm confusion ECDSA	Modérée	3.4.0

Évaluation contexte PNPI :

- **JWT bomb (CVE-2024-33664)** : exploitation possible uniquement si un attaquant non authentifié peut soumettre un token JWE compressé. La PNPI n'utilise que des JWS signés (HMAC-SHA256), pas de JWE. **Impact réel : faible.**
- **Algorithm confusion (CVE-2024-33663)** : exploitable si l'application accepte plusieurs algorithmes lors du `decode` . La PNPI verrouille `algorithms=["HS256"]` dans `core/auth.py:142` . **Impact réel : nul.**

Action recommandée : `pip install python-jose==3.4.0` puis `pytest` de régression. Bloquer dans `requirements.txt` à `>=3.4.0,<4` .

2.2 Frontend Node.js (npm audit)

PACKAGE	VERSION ACTUELLE	ADVISORY	SÉVÉRITÉ	FIX
next	14.2.35	GHSA-9g9p-9gw9-jx7f — DoS Image Optimizer remotePatterns	Élevée	15.5.10+
next	14.2.35	GHSA-h25m-26qc-wcjf — DoS RSC deserialization	Modérée	15.0.8+
next	14.2.35	GHSA-ggv3-7p47-pfv8 — HTTP request smuggling rewrites	Modérée	15.5.13+
next	14.2.35	GHSA-3x4c-7xq6-9pq8 — Image cache exhaustion	Modérée	15.5.14+
next	14.2.35	GHSA-q4gf-8mx6-v5v3 — DoS Server Components	Modérée	15.5.15+
postcss	<8.5.10	GHSA-qx2v-qp2m-jg93 — XSS via unescaped <code></style></code>	Modérée	transitive Next.js

Évaluation contexte PNPI :

- Les advisories Next.js sont toutes **DoS** (Denial of Service), pas de RCE ni d'exfiltration. La PNPI n'expose pas `/_next/image` à des hôtes tiers (`remotePatterns` vide), ce qui neutralise l'attaque principale (DoS Image Optimizer).
- Aucun **backport** des correctifs sur la branche `14.2.x` (politique Vercel : seule la branche `15.x` est patchée). La PNPI est sur la **dernière version stable de la branche 14** (14.2.35).
- L'advisory `postcss` ne s'applique qu'aux pipelines de build (pas exécuté côté client en production). **Impact réel : nul** sur l'app publiée.

Action recommandée : maintenir `next@14.2.35` jusqu'à l'audience (déjà la dernière version stable de la branche 14). **Migrer vers `next@15.5+` post-J0** (breaking changes App Router : `next/headers` , `middleware`, `fetch caching` à valider). Cette migration est prévue dans le plan J0-J90 (cf. `docs/architecture/plan-mise-en-prod-j0-j90.md`).

3. Analyse statique du code Python (`bandit`)

26 alertes sur 20 563 lignes (densité = 1.3 alerte / 1 000 LOC, ce qui est **très bon** — référence Django ~5/1000).

CODE	SÉVÉRITÉ	FAMILLE	OCCURRENCES	VERDICT
B104	Medium	<code>hardcoded_bind_all_interfaces</code>	1 (<code>webhooks.py:26</code>)	Faux positif — string <code>0.0.0.0</code> dans un commentaire de configuration.
B608	Medium	<code>hardcoded_sql_expressions</code>	1 (<code>main.py:2847</code>)	Faux positif — voir §3.1 ci-dessous.
B105	Low	<code>hardcoded_password_string</code>	18	Tous faux positifs — strings comme <code>"password"</code> , <code>"secret"</code> dans noms de champs ou messages d'erreur.
B110	Low	<code>try_except_pass</code>	4	Acceptable — patterns de fallback (cache miss, audit best-effort).
B404 / B603	Low	<code>subprocess</code>	2 (<code>admin.py</code>)	Acceptable — endpoint admin protégé <code>Role.admin</code> , args validés.

3.1 Focus B608 — `main.py:2847` (faux positif documenté)

```
@app.get("/admin/db-tables", tags=["Admin"])
async def db_tables_info(
    _: User = Depends(require_roles(Role.admin)), # auth admin obligatoire
    db: Session = Depends(get_db),
):
    inspector = sa_inspect(engine)
    for table_name in sorted(inspector.get_table_names()): # source = SQLAlchemy, PAS
        ...
        row_count = db.execute(text(f'SELECT COUNT(*) FROM "{table_name}"')).scalar()
```

`table_name` provient exclusivement de `inspector.get_table_names()` (introspection SQLAlchemy du schéma), **jamais d'une entrée utilisateur**. L'endpoint exige `Role.admin`. Aucune surface d'injection. Documentation possible avec un commentaire `# nosec B608 – table_name from schema introspection`.

4. Analyse statique multi-langages (`semgrep`)

2 alertes sur 411 fichiers (231 règles OWASP Top 10 + Python + TypeScript).

4.1 ERROR — `avoid-sqlalchemy-text` (`main.py:2847`)

Doublon du B608 ci-dessus. Même analyse : faux positif.

4.2 WARNING — `wildcard-cors` (`main.py:2585`)

```
if CORS_ALLOW_ORIGINS_RAW == "*":
    cors_allow_origins = ["*"] # uniquement si env explicite
else:
    cors_allow_origins = [origin.strip() for origin in CORS_ALLOW_ORIGINS_RAW.split(",")

app.add_middleware(
    CORSMiddleware,
    allow_origins=cors_allow_origins,
    allow_credentials=False, # cookies httpOnly NON exposés en wildcard
    ...
)
```

Évaluation : - Le wildcard n'est activé **que** si `PNPI_CORS_ALLOW_ORIGINS=*` est explicitement défini (jamais en production). - `allow_credentials=False` : empêche l'exposition des cookies de session via le wildcard. - En `docker-compose.prod.yml` , la valeur défaut est `https://pnpi.industrie.gouv.ga` .

Verdict : configuration **safe par défaut**, mais ajouter une assertion runtime au démarrage : si `PNPI_ENV=production` et `PNPI_CORS_ALLOW_ORIGINS=*` , faire crash le boot. Effort : 5 lignes.

5. Recoupement avec les contrôles de sécurité PNPI

L'absence de findings critiques s'explique par les protections déjà en place, validées au cours du **lot 79** (audit ingénieurs seniors) et du **lot 80** (audit sectoriel) :

CONTRÔLE	IMPLÉMENTATION	LOCALISATION
Anti-IDOR opérateur	Helper check_ati_access obligatoire sur /pnpi/ati/{id}/*	backend/app/routers/ati.py:check_ati_access
Anti-XSS	SanitizedStr Pydantic + bleach + Content-Security- Policy headers	backend/app/core/sanitize.py , main.py
Anti-CSRF	Middleware origin check sur POST/PUT/DELETE	backend/app/core/csrf.py
Rate limiting	Redis sliding window (60 req/min IP, 10 req/min login)	backend/app/core/rate_limiter.py
Captcha login	Math challenge après 3 échecs IP	backend/app/routers/auth.py
Mots de passe	bcrypt (rounds=12), policy 12 chars + classe variée	backend/app/core/auth.py
JWT	HS256 only, TTL 8h, cookie httpOnly + Secure + SameSite=Lax	backend/app/core/auth.py
Chiffrement at- rest	NIF chiffré Fernet (AES-128-CBC + HMAC)	backend/app/core/encryption.py
Anonymisation Open Data	k-anonymity (k≥5) sur datasets publics	backend/app/routers/open_data.py
Audit trail	Toutes mutations tracées (actor , action , target , details)	backend/app/core/audit.py
Validation uploads	Magic bytes + extension + taille	backend/app/core/upload_validation.py

CONTRÔLE	IMPLÉMENTATION	LOCALISATION
(10/50 MB)		
Headers sécurité	HSTS, X-Frame-Options, X-Content-Type-Options, CSP	backend/app/main.py (middleware)

6. Limitations de l'audit

6.1 OWASP ZAP baseline scan — différé

Le scan ZAP runtime (DAST sur les 60 endpoints `/api/*`) **n'a pas été exécuté** : un conflit de version `fastapi 0.136` / `starlette` empêche actuellement le boot du backend en local Windows (`Router.__init__()` got an unexpected keyword argument `'on_startup'`). Ce blocage est **étranger** au pentest et fait l'objet du ticket de dette technique R-018 (cf. `docs/architecture/risk-register.md`).

Mitigation : le CI GitHub Actions (Ubuntu, Python 3.12) ne reproduit pas ce bug. Le ZAP scan sera ré-exécuté lors du prochain CI nominal et joint en annexe de cet audit.

6.2 Audit externe humain — recommandé post-signature

Cet audit interne **ne remplace pas** un pentest externe humain réalisé par un cabinet certifié (ex : Synacktiv, HackerOne, Wallix). Un pentest humain teste :

- Les **logiques métier** complexes (ex : workflow ATI, recours, transitions de statuts) — non couvertes par les scanners.
- L'**escalade de privilèges multi-rôles** dans les scénarios réels.
- La **sécurité physique** des serveurs de prod (à voir avec ANINF/Direction Informatique du Ministère).
- Le **social engineering** (phishing, impersonation).

Budget indicatif : 3 à 8 millions FCFA pour un pentest 5 jours sur application web. À budgéter dans le plan post-J0 (cf. `docs/architecture/plan-mise-en-prod-j0-j90.md`).

7. Plan d'action — checklist avant audience

Avant audience (effort ≤ 4h)

- [x] **Backend** : `pip install "python-jose>=3.4.0,<4"` (3.5.0 installé) — pip-audit confirme **0 vulnérabilité Python**
- [x] **Backend** : épingler `python-jose>=3.4.0,<4` dans `backend/requirements.txt`
- [x] **Frontend** : `npm install next@^14.2.32` (14.2.35 installé, dernière de la branche 14)
- [] **Backend** : ajouter assertion runtime sur `PNPI_CORS_ALLOW_ORIGINS=*` en production (`backend/app/config.py validator`)
- [] **Backend** : annoter `# nsec B608` avec justification sur `main.py:2847`
- [] **Frontend** : test E2E full (`npm run build` + `npm run test:e2e`) après upgrade Next.js

Après signature de la convention (J0+30)

- [] Programmer le pentest externe humain (cabinet certifié ANSSI ou équivalent)
- [] **Migrer Next.js 14.2.35 → 15.5+** pour résoudre les 5 advisories DoS (breaking changes App Router à valider)
- [] Réactiver le ZAP scan dans CI GitHub Actions (résolution du blocker fastapi/starlette)
- [] Mise en place SAST continu (Semgrep app cloud avec rapports hebdomadaires)
- [] Audit infra prod par ANINF/Direction Informatique (sécurité physique, accès SSH, backup)

8. Annexes — fichiers techniques

Tous les fichiers JSON bruts (entrée des scanners) sont versionnés dans le repository pour reproductibilité :

```
docs/audit-securite-interne/
├── 00-rapport-audit-interne.md  ← ce document
├── pip-audit.json              ← 4 findings (python-jose)
├── npm-audit.json              ← 6 findings (next, postcss)
├── bandit.json                 ← 26 findings (24 low, 2 medium)
└── semgrep.json                ← 2 findings (1 SQL, 1 CORS)
```

Pour reproduire :

```
# Backend
pip install pip-audit bandit semgrep
cd backend && pip-audit -r requirements.txt --format json -o pip-audit.json
bandit -r app/ -f json -o bandit.json

# Frontend
cd frontend && npm audit --production --json > npm-audit.json

# Combined
semgrep --config p/python --config p/typescript --config p/owasp-top-ten \
--json -o semgrep.json backend/app frontend/src
```

9. Conclusion

La PNPI présente un **profil de sécurité robuste pour une plateforme gouvernementale en pré-production**, avec :

- Aucune vulnérabilité critique exploitable.
- Des correctifs mineurs (~4 heures) pour atteindre **0 finding haute sévérité** avant l'audience.
- Une couverture défensive multi-niveaux (anti-IDOR, CSRF, rate-limiting, chiffrement at-rest, audit trail) déjà en place.
- Un plan post-signature clair pour pentest externe et audit infra ANINF.

Cet audit interne est versé au dossier de présentation au Ministère. Il démontre une démarche **proactive et transparente** de gestion du risque — un argument fort en faveur de la posture C (Hybride) défendue dans le cadrage stratégique.

Document généré le 2026-05-01 · PNPI v1.27.0 · commit `e5a38ce` · Outils : pip-audit 2.x, npm 10.x, bandit 1.x, semgrep 1.161
